МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ

КИЇВСЬКИЙ НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ ІМЕНІ ТАРАСА ШЕВЧЕНКА

ФАКУЛЬТЕТ ІНФОРМАЦІЙНИХ ТЕХНОЛОГІЙ

КАФЕДРА ІНФОРМАЦІЙНИХ СИСТЕМ ТА ТЕХНОЛОГІЙ

Лабораторна робота № 1

з дисципліни **«Кібернетична безпека підприємства»**

Тема: «Дослідження структури системи управління кібернетичною безпекою військкомату (територіального центру комплектування та соціальної підтримки)»

Виконав:

студент гр. ІР-31

Петро Кравченко

Перевірив:

Зараховано від

Борисенко Ірина Ігорівна

_____

(підпис викладача)

Київ-2026

ЗМІСТ

1. МЕТА ТА ЗАВДАННЯ РОБОТИ 4
2. ПОНЯТТЯ, ЦІЛІ ТА ЗАВДАННЯ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ 5
2.1. Поняття інформаційної та кібернетичної безпеки 5
2.2. Цілі інформаційної безпеки та принципи кібербезпеки 5
2.3. Завдання та стадії побудови системи управління інформаційною безпекою 6
3. АНАЛІЗ СТАНДАРТУ ISO/IEC 27001:2022 8
3.1. Призначення та структура стандарту 8
3.2. Додаток А: перелік заходів безпеки 9
3.3. Зміни редакції 2022 року та процесний цикл 10
4. ЗАСТОСУВАННЯ ISO/IEC 27001:2022 ДЛЯ ОРГАНІЗАЦІЇ КІБЕРБЕЗПЕКИ ТЦК ТА СП 12
4.1. Характеристика об’єкта дослідження 12
4.2. Контекст організації та область застосування СУІБ 13
4.3. Лідерство, політика та ролі 14
4.4. Етапи впровадження СУІБ 14
5. МОДЕЛЬ СИСТЕМИ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ ТЦК ТА СП 16
5.1. Об’єкти захисту 16
5.2. Модель порушника 17
5.3. Загрози та вразливості 18
5.4. Структурна модель системи інформаційної безпеки 19
5.5. Архітектура периметра захисту 20
6. КІБЕРБЕЗПЕКА ТЦК ТА СП НА БАЗІ ISO/IEC 27001 23
6.1. Процес управління ризиками 23
6.2. Оцінка ризиків 23
6.3. Обробка ризиків і Декларація про застосовність 24
6.4. Узгодження з національною нормативною базою 25
7. СТАНДАРТИ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ ДЛЯ ТЦК ТА СП 27

8. ВІДПОВІДІ НА ПИТАННЯ ДЛЯ САМОПЕРЕВІРКИ 30
ВИСНОВКИ 33
СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ 34

1. МЕТА ТА ЗАВДАННЯ РОБОТИ

Мета роботи — проаналізувати структуру системи управління кібернетичною безпекою підприємства та основні стандарти в цій галузі [1]. Об’єктом дослідження за індивідуальним варіантом № 24 є військкомат — районний територіальний центр комплектування та соціальної підтримки (далі — ТЦК та СП), правовий статус якого визначає Положення, затверджене постановою Кабінету Міністрів України № 154 [2].

Завдання роботи відповідно до методичних рекомендацій [1]:

1) ознайомитися з поняттям та основними положеннями інформаційної безпеки, дослідити її основні цілі та завдання (розділ 2);

2) проаналізувати стандарт ISO/IEC 27001:2022 (розділ 3);

3) дослідити застосування стандарту ISO/IEC 27001:2022 для організації кібернетичної безпеки на підприємстві (розділ 4);

4) зобразити модель системи інформаційної безпеки підприємства відповідно до індивідуального варіанта (розділ 5);

5) виконати представлення кібернетичної безпеки підприємства на базі міжнародних стандартів ISO/IEC 27001 (розділ 6);

6) дослідити інші стандарти в галузі інформаційної безпеки та заповнити таблицю стандартів, придатних для захисту обраного підприємства (розділ 7).

Відповіді на питання для самоперевірки наведено в розділі 8, аналіз результатів — у висновках. Звіт оформлено відповідно до ДСТУ 3008:2015 [3].

Примітка. ТЦК та СП, його підрозділи, мережа й показники ризиків у роботі є умовною навчальною моделлю, побудованою лише на відкритих нормативних джерелах.

2. ПОНЯТТЯ, ЦІЛІ ТА ЗАВДАННЯ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ

2.1. Поняття інформаційної та кібернетичної безпеки

Інформаційна безпека — це стан (рівень) захищеності інформаційних ресурсів, тобто інформаційних об’єктів і інформаційних систем, від випадкових і навмисних негативних впливів, які можуть завдати шкоди самій інформації, засобам її передавання та обробки, а отже її власникам, державі та суспільству [1]. Узагальнено інформаційну безпеку визначають як сукупність засобів, методів і процедур, що забезпечують захист інформаційних активів і зберігають ефективність технічної інфраструктури та відомостей, які в ній обробляються [4].

Кібербезпека підприємства ширша за захист окремих даних: це сукупність організаційних, правових, програмно-технічних і технологічних заходів, спрямованих на захист інформації, інформаційних систем, мереж, програмного забезпечення, пристроїв і бізнес-процесів від кіберзагроз [5]. Жоден окремий засіб (міжмережевий екран, антивірус, SIEM) не забезпечує повноцінного захисту; об’єктом захисту є також процеси, у яких інформація створюється та використовується. Законодавчо кібербезпеку визначено як захищеність життєво важливих інтересів людини і громадянина, суспільства та держави під час використання кіберпростору [6].

Для ТЦК та СП така процесна позиція має прямий зміст. Наслідком компрометації є не лише розголошення персональних даних, а й зрив оповіщення, спотворення облікових відомостей, від яких залежать права громадян, і порушення мобілізаційної роботи держави в умовах воєнного стану.

2.2. Цілі інформаційної безпеки та принципи кібербезпеки

Основними цілями інформаційної безпеки є конфіденційність, неможливість несанкціонованого доступу, цілісність інформації та пов’язаних з нею процесів, доступність, мінімізація ризиків шляхом компенсаційних заходів і облік усіх процесів, пов’язаних з ризиками [1]. Ядро цих цілей

утворює модель CIA (конфіденційність, цілісність, доступність); її доповнюють принципи автентичності, підзвітності, найменших привілеїв, багаторівневого захисту (Defense in Depth), Security by Design і Zero Trust [5]. У табл. 1.1 кожну ціль конкретизовано для ТЦК та СП.

Таблиця 1.1 — Цілі та принципи кібербезпеки в контексті ТЦК та СП

Ціль / принцип	Зміст	Конкретизація для ТЦК та СП
Конфіденційність	доступ до інформації лише уповноважених суб'єктів	дані Реєстру та ВЛК доступні лише операторам відповідних відділень; секретні документи — лише особам з допуском
Цілісність	точність, повнота й незмінність інформації, крім санкціонованих змін	кожна зміна облікового запису військовозобов'язаного обґрунтована документом і фіксується в журналі
Доступність	своєчасне використання ресурсів уповноваженими суб'єктами	Реєстр, оповіщення й електронна черга доступні під час відключень живлення та атак
Автентичність	підтвердження справжності суб'єкта, пристрою чи джерела	багатофакторна автентифікація операторів, сертифікати вузлів обміну
Підзвітність	встановлення відповідності між дією та суб'єктом	захищені журнали дій операторів як засіб протидії корупційному втручанню
Найменші привілеї	лише мінімально необхідні права	рольовий доступ: працівник центру обслуговування не бачить медичних висновків
Багаторівневий захист	кілька незалежних рівнів механізмів безпеки	периметр, сегментація, КЗІ, EDR, SIEM, резервні копії (рис. 1.4)
Zero Trust	жоден суб'єкт не вважається довіреним автоматично	перевірка кожного підключення до Реєстру незалежно від розташування у внутрішній мережі

2.3. Завдання та стадії побудови системи управління інформаційною безпекою

Досягнення цілей забезпечується розв'язанням таких завдань [1]: введення термінології; класифікація інформаційних ресурсів; визначення власників процесів, відповідальних за безпеку; розроблення спектра ризиків та їх експертне оцінювання; визначення груп доступу; розроблення системи управління ризиками; складання переліків адміністративних і технічних заходів; виконання заходів і періодичний контроль ризиків; забезпечення

фізичної безпеки та безпеки персоналу; формування вимог безпеки до інформаційної системи; контролінг безпеки.

Реалізація системи управління інформаційною безпекою (СУІБ) проходить чотири стадії: формування політики в галузі ризиків, аналіз бізнес-процесів, аналіз ризиків і формування цільової концепції [1]. Для ТЦК та СП ці стадії виконано в розділах 4–6: політика й контекст (розділ 4), процеси та активи (підрозділи 4.1 і 5.1), ризики та цільова модель захисту (розділ 6).

Загрози класифікують за природою (випадкові та навмисні) і за відношенням до об’єкта (зовнішні та внутрішні) [1]. Порушення бувають організаційно-правовими, організаційними, фізичними та радіоелектронними; для ТЦК та СП актуальні всі чотири види, що обґрунтовує комплексний характер СУІБ.

3. АНАЛІЗ СТАНДАРТУ ISO/IEC 27001:2022

3.1. Призначення та структура стандарту

ISO/IEC 27001:2022 встановлює вимоги до створення, впровадження, підтримання та постійного поліпшення системи управління інформаційною безпекою в контексті організації, а також до оцінювання й обробки ризиків інформаційної безпеки [7]. СУІБ є частиною загальної системи управління, що ґрунтується на аналізі ризиків; її складають організаційні структури, політика, планування, обов’язки, процедури, процеси і ресурси [1]. В Україні стандарт прийнято як ідентичний національний — ДСТУ ISO/IEC 27001:2023, що замінив ДСТУ ISO/IEC 27001:2015 [8].

Стандарт має уніфіковану структуру систем менеджменту: розділи 0–3 (вступ, сфера, посилання, терміни) мають довідковий характер, а обов’язкові вимоги містять розділи 4–10, наведені в табл. 1.2. Відхилення від вимог розділів 4–10 не допускаються, якщо організація заявляє про відповідність стандарту.

Таблиця 1.2 — Обов’язкові розділи ISO/IEC 27001:2022 та їх застосування в ТЦК та СП

Розділ	Назва	Основні вимоги	Застосування в ТЦК та СП
4	Контекст організації	зовнішні та внутрішні чинники, зацікавлені сторони, область застосування СУІБ	воєнний стан, вимоги МО, законів і НД ТЗІ; межі СУІБ — процеси П1–П7
5	Лідерство	зобов’язання керівництва, політика ІБ, ролі та повноваження	начальник ТЦК та СП затверджує політику, призначає керівника СУІБ і службу захисту інформації
6	Планування	оцінювання й обробка ризиків, Декларація про застосовність, цілі ІБ, планування змін	реєстр ризиків З-01…З-10, вибір заходів додатка А
7	Підтримка	ресурси, компетентність, обізнаність, комунікація, документована інформація	допуск персоналу, навчання з протидії фішингу, облік документів
8	Функціонування	планування й контроль процесів, виконання оцінювання та обробки ризиків	впровадження КСЗІ, сегментації, резервування
9	Оцінювання результативності	моніторинг і вимірювання, внутрішній аудит, аналіз керівництвом	метрики SIEM, щоквартальний внутрішній аудит
10	Поліпшення	постійне поліпшення, невідповідності та коригувальні дії	усунення причин інцидентів, оновлення політик

3.2. Додаток А: перелік заходів безпеки

Нормативний додаток А містить 93 заходи безпеки, згруповані в чотири теми (табл. 1.3); у редакції 2013 р. було 114 заходів у 14 доменах. Організація зобов’язана порівняти обрані заходи з додатком А, обґрунтувати включення чи виключення кожного з них і зафіксувати це в Декларації про застосовність (Statement of Applicability, далі — ДЗ) [7]. Настанови щодо впровадження заходів наведено в ISO/IEC 27002:2022, де кожному заходу присвоєно атрибути: тип (запобіжний, виявляючий, коригувальний), властивості ІБ (К, Ц, Д), концепції кібербезпеки (ідентифікувати, захищати, виявляти, реагувати, відновлювати), операційні можливості та домени безпеки [9].

Таблиця 1.3 — Теми заходів додатка А ISO/IEC 27001:2022 (усього 93)

Тема	Кількість заходів	Зміст	Пріоритетні для ТЦК та СП
5 Організаційні	37	політики, ролі, класифікація, доступ, постачальники, інциденти, неперервність, захист персональних даних	5.1, 5.12, 5.15, 5.19–5.23, 5.24–5.28, 5.30, 5.34
6 Щодо персоналу	8	перевірка кандидатів, умови праці, навчання, дисциплінарний процес, NDA	6.1 (спецперевірка для допуску), 6.3, 6.4, 6.6
7 Фізичні	14	периметри, вхід, моніторинг, захищені зони, носії, живлення, утилізація	7.1–7.4, 7.6, 7.10, 7.11, 7.14
8 Технологічні	34	кінцеві пристрої, автентифікація, шкідливе ПЗ, вразливості, журналювання, мережі, криптографія, безпечна розробка	8.2, 8.5, 8.7, 8.8, 8.12, 8.13, 8.15, 8.16, 8.20–8.24

3.3. Зміни редакції 2022 року та процесний цикл

Редакція 2022 р. додала вимогу планування змін СУІБ (6.3), уточнила вимоги до процесів (4.4, 8.1) і змінила порядок підрозділів розділу 10. Серед заходів з’явилися 11 нових: розвідувальні дані про загрози (5.7), безпека хмарних сервісів (5.23), готовність ІКТ до неперервності (5.30), моніторинг фізичної безпеки (7.4), керування конфігураціями (8.9), видалення інформації (8.10), маскування даних (8.11), запобігання витоку даних (8.12), моніторинг діяльності (8.16), вебфільтрація (8.23) і безпечне кодування (8.28) [9]. Для ТЦК та СП найважливішими з них є 5.7, 5.30, 8.12 і 8.16, оскільки основні загрози мають державне походження, а витоки персональних даних мають високий суспільний резонанс.

Розділи 4–10 утворюють цикл «планування — виконання — перевірка — поліпшення» (PDCA), що забезпечує постійне вдосконалення СУІБ; той самий цикл застосовують і до управління кіберінцидентами [10]. Застосування стандарту дає змогу встановити вимоги й цілі безпеки, переконатися в результативності управління ризиками та відповідності законодавству,

контролювати впровадження СУІБ і надавати аудиторам та партнерам підтвердження рівня захищеності [1].

4. ЗАСТОСУВАННЯ ISO/IEC 27001:2022 ДЛЯ ОРГАНІЗАЦІЇ КІБЕРБЕЗПЕКИ ТЦК ТА СП

4.1. Характеристика об’єкта дослідження

ТЦК та СП є органом військового управління, що забезпечує виконання законодавства з питань військового обов’язку, військової служби та мобілізаційної підготовки, веде військовий облік і здійснює соціальну підтримку військовослужбовців та членів їхніх сімей [2]. ТЦК та СП є органом ведення Єдиного державного реєстру призовників, військовозобов’язаних та резервістів (електронна система «Оберіг»), держателем якого є Міністерство оборони України [11].

Умовну організаційну структуру районного ТЦК та СП з розподілом ролей СУІБ подано на рис. 1.1. Начальник є власником ризиків, заступник — керівником СУІБ, служба захисту інформації разом з режимно-секретним органом (РСО) контролює дотримання політик у всіх підрозділах.

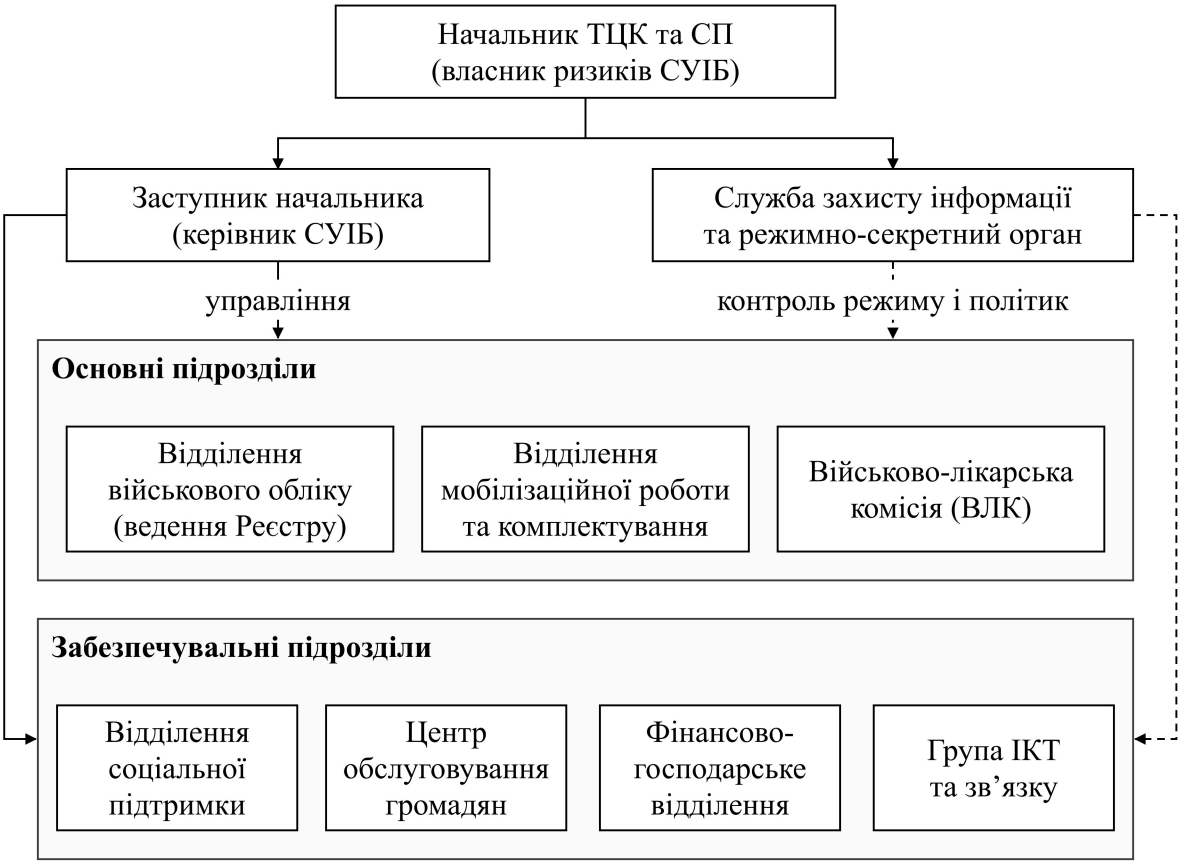


Рис. 1.1 — Умовна організаційна структура ТЦК та СП з ролями СУІБ

Основні процеси ТЦК та СП, які утворюють область застосування СУІБ, і їхні інформаційні ресурси наведено в табл. 1.4.

Таблиця 1.4 — Процеси ТЦК та СП в області застосування СУІБ

Код	Процес	Виконавець	Інформаційні ресурси
П1	Ведення військового обліку призовників, військовозобов’язаних і резервістів	Відділення військового обліку	АРМ органу ведення Реєстру «Оберіг», документообіг
П2	Оповіщення та виклик громадян, оформлення документів	Відділення мобілізаційної роботи та комплектування	Реєстр, засоби друку та фотофіксації
П3	Медичний огляд військово-лікарською комісією	ВЛК	АРМ ВЛК, база медичних висновків
П4	Мобілізаційна робота за розпорядженнями вищих органів	Відділення мобілізаційної роботи та комплектування, РСО	Автономні АРМ ізольованої зони
П5	Прийом громадян та електронна черга	Центр обслуговування громадян	Вебсервіс черги, телефонна лінія
П6	Соціальна підтримка військовослужбовців і членів їхніх сімей	Відділення соціальної підтримки	Документообіг, обмін із соціальними органами
П7	Міжвідомчий обмін даними (МО, Генштаб ЗСУ, ДПСУ, обласний ТЦК та СП)	Група ІКТ та зв’язку	Криптошлюз КЗІ, відомча мережа

4.2. Контекст організації та область застосування СУІБ

Відповідно до розділу 4 стандарту [7] визначено зовнішні та внутрішні чинники. Зовнішні: воєнний стан і постійні кібератаки держави-агресора, висока суспільна увага до діяльності ТЦК та СП, залежність від відомчих систем МО та каналів зв’язку, нестабільне електроживлення. Внутрішні: обмежена чисельність ІТ-персоналу, велика кількість операторів з доступом до персональних даних, поєднання відкритої, службової та секретної інформації в одній установі.

Зацікавлені сторони та їхні вимоги:

– Міністерство оборони та Генеральний штаб ЗСУ — цілісність і доступність даних Реєстру, дотримання відомчих правил обміну [11];

– громадяни — захист персональних і медичних даних, законність обробки, доступність прийому [12];

– Держспецзв’язку та CERT-UA — створення КСЗІ з підтвердженою відповідністю, повідомлення про кіберінциденти [6; 13];

– СБУ та органи, що здійснюють режим секретності, — охорона державної таємниці [14];

– ДПСУ та обласний ТЦК та СП — своєчасний і захищений обмін відомостями.

Область застосування СУІБ: процеси П1–П7, інформаційні активи А-01…А-12, приміщення ТЦК та СП і канали обміну до точки підключення до відомчої мережі. Поза областю залишаються центральні компоненти Реєстру «Оберіг», за безпеку яких відповідають держатель (він же адміністратор) і розпорядник Реєстру, однак інтерфейси до них входять до СУІБ.

4.3. Лідерство, політика та ролі

Згідно з розділом 5 стандарту начальник ТЦК та СП затверджує політику інформаційної безпеки, забезпечує ресурси й інтеграцію вимог СУІБ у процеси. Політика визначає цілі (табл. 1.1), принцип найменших привілеїв, порядок класифікації інформації за грифами, обов’язкову багатофакторну автентифікацію і порядок реагування на інциденти. Ролі: власник ризиків — начальник; керівник СУІБ — заступник; служба захисту інформації — адміністратор безпеки, аналітик подій, відповідальний за захист персональних даних; власники активів — керівники відділень (табл. 1.5).

4.4. Етапи впровадження СУІБ

Цикл впровадження СУІБ ТЦК та СП подано на рис. 1.2. На вході цикл отримує вимоги зацікавлених сторін, на виході — керовану кібербезпеку критичних процесів.

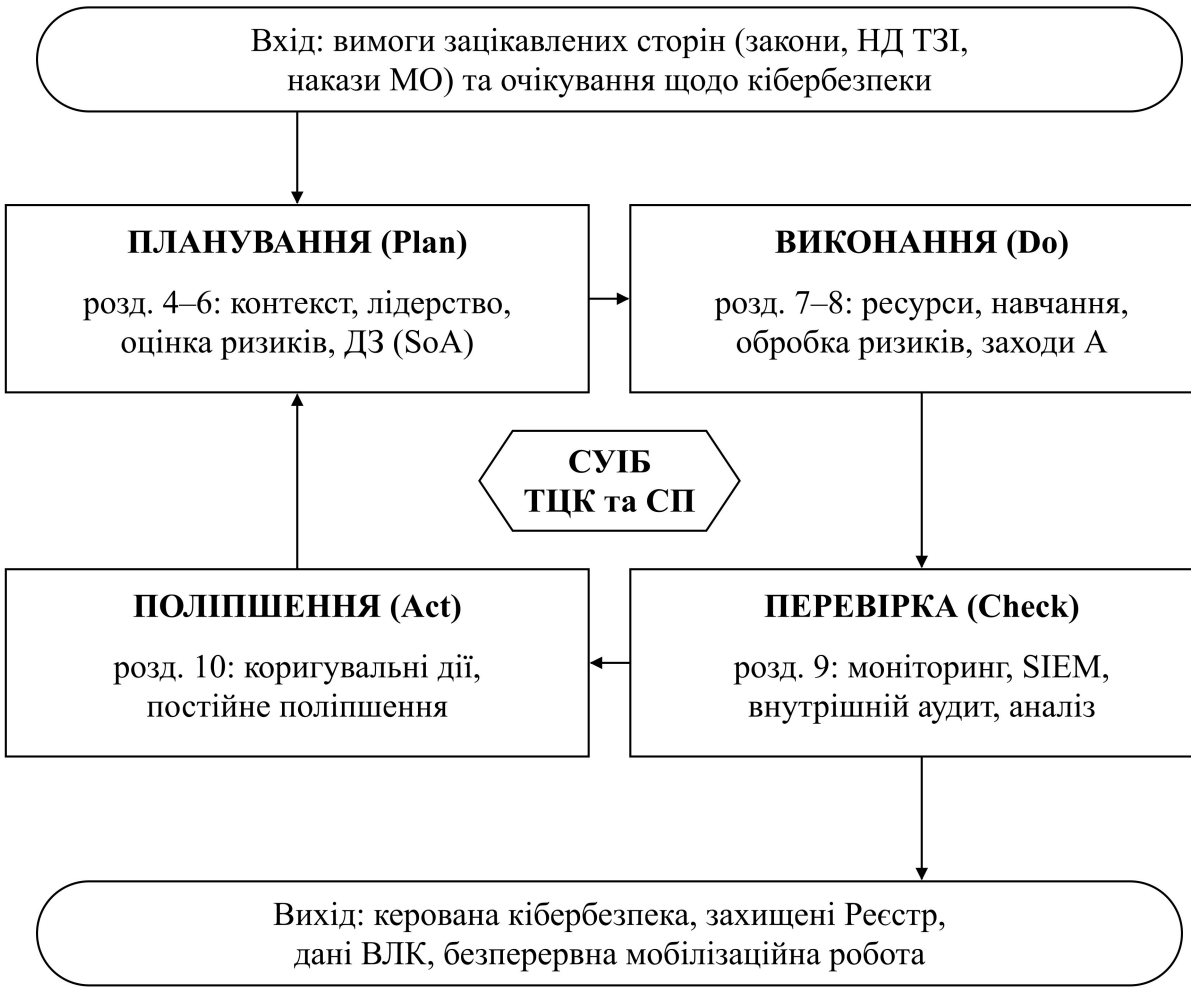


Рис. 1.2 — Цикл PDCA СУІБ ТЦК та СП за розділами 4–10 ISO/IEC 27001:2022

1) Планування (розділи 4–6): аналіз контексту, затвердження політики, ідентифікація активів, оцінка ризиків, складання ДЗ і плану обробки ризиків.

2) Виконання (розділи 7–8): забезпечення ресурсами, навчання персоналу, створення КСЗІ за НД ТЗІ 3.7-003-05 [15], впровадження технічних і організаційних заходів.

3) Перевірка (розділ 9): моніторинг подій у SIEM, метрики результативності, внутрішній аудит, аналіз керівництвом.

4) Поліпшення (розділ 10): усунення невідповідностей, коригувальні дії за результатами інцидентів і аудитів, перегляд ризиків.

5. МОДЕЛЬ СИСТЕМИ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ ТЦК ТА СП

5.1. Об’єкти захисту

Модель системи інформаційної безпеки підприємства — це сукупність зовнішніх і внутрішніх чинників та їх впливу на стан безпеки й збереження ресурсів; вона пов’язує загрози, вразливості та ризики [1]. Об’єктами захисту є інформаційні, програмні, апаратні, мережеві ресурси та бізнес-процеси [5]. Реєстр активів ТЦК та СП з оцінкою критичності за властивостями К, Ц, Д (1 — низька, 3 — висока) наведено в табл. 1.5.

Таблиця 1.5 — Реєстр інформаційних активів ТЦК та СП

Код	Актив	Вид	Власник	Категорія інформації	К	Ц	Д
А-01	Відомості Реєстру призовників, військовозобов’язаних та резервістів (дані органу ведення)	інформаційний	Начальник відділення військового обліку	персональні дані; службова інформація	3	3	3
А-02	Медичні висновки та протоколи ВЛК	інформаційний	Голова ВЛК	персональні дані особливої категорії (здоров’я)	3	3	2
А-03	Мобілізаційні розпорядження та плани	інформаційний	Начальник ТЦК та СП	державна таємниця	3	3	3
А-04	Біометричні дані та фотозображення громадян	інформаційний	Начальник відділення військового обліку	персональні дані особливої категорії	3	3	1
А-05	Засоби криптографічного захисту, ключові документи	апаратний	Начальник групи ІКТ та зв’язку	службова інформація	3	3	3

Продовження таблиці 1.5

Код	Актив	Вид	Власник	Категорія інформації	К	Ц	Д
А-06	АРМ операторів і сервер документообігу	апаратний / програмний	Начальник групи ІКТ та зв’язку	службова інформація	2	3	3
А-07	Канали міжвідомчого обміну (відомча мережа, VPN)	мережевий	Начальник групи ІКТ та зв’язку	службова інформація	3	3	3
А-08	Вебсервіс електронної черги та публічна сторінка	програмний	Начальник центру обслуговування	відкрита інформація; персональні дані заявників	2	2	3
А-09	Облікові записи та права доступу персоналу	інформаційний	Служба захисту інформації	службова інформація	3	3	2
А-10	Журнали подій безпеки та резервні копії	інформаційний	Служба захисту інформації	службова інформація	2	3	2
А-11	Персонал, допущений до Реєстру та таємних документів	людський	Заступник начальника	—	3	2	3
А-12	Бізнес-процес оповіщення та мобілізації (П2, П4)	бізнес-процес	Начальник ТЦК та СП	—	3	3	3

Максимальну критичність за всіма трьома властивостями мають 5 активів (А-01, А-03, А-05, А-07, А-12): відомості Реєстру, мобілізаційні документи, засоби КЗІ, канали обміну та процес мобілізації. Медичні та біометричні дані належать до особливих категорій персональних даних, обробка яких допускається лише у випадках, визначених статтею 7 Закону [12].

5.2. Модель порушника

Модель порушника — формалізований опис потенційного суб’єкта загрози, його мотивації, рівня доступу, знань і можливостей [16]. За лекцією виділено чотири рівні можливостей: від використання штатного ПЗ (1) до повноважень, співставних з адміністративними (4). Модель порушника ТЦК та СП наведено в табл. 1.6.

Таблиця 1.6 — Модель порушника ТЦК та СП

Код	Порушник	Категорія	Мотивація	Рівень	Типові дії
ПР-1	Державне APT-угруповання держави-агресора	зовнішній, організований високоресурсний	розвідка, дестабілізація мобілізації	4	цільовий фішинг, підміна оновлень, тривала прихована присутність
ПР-2	Хактивістське угруповання	зовнішній, віддалений активний	репутаційний вплив, пропаганда	2	DDoS на сервіс черги, дефейс, публікація викрадених даних
ПР-3	Корумпований працівник (інсайдер)	внутрішній, пасивний (обережний)	фінансова вигода, «вирішення питань»	3	несанкціонований перегляд і зміна записів, продаж даних
ПР-4	Необізнаний працівник	внутрішній, випадковий	відсутня (помилка)	1	відкриття шкідливого вкладення, втрата носія, слабкий пароль
ПР-5	Скомпрометований постачальник ПЗ або сервісу	зовнішній через довірений канал	використовується ПР-1	3	шкідливе оновлення, віддалений доступ підрядника
ПР-6	Диверсант або сторонній відвідувач	зовнішній з фізичним доступом	знищення, викрадення, встановлення закладок	2	доступ до АРМ, підключення пристрою, пошкодження обладнання

Найнебезпечнішим є поєднання зовнішнього високоресурсного порушника ПР-1 з внутрішнім ПР-3 або скомпрометованим постачальником ПР-5: легітимний доступ інсайдера чи довіреного каналу дозволяє обійти периметр, тому модель захисту ґрунтується на принципі Zero Trust [5].

5.3. Загрози та вразливості

Загрози ідентифіковано за методологією STRIDE, що аналізує шість категорій: підміну особи (S), модифікацію даних (T), заперечення дій (R), розкриття інформації (I), відмову в обслуговуванні (D) та підвищення привілеїв (E) [17]. Перелік загроз з відповідними вразливостями наведено в табл. 1.7.

Таблиця 1.7 — Загрози та вразливості ТЦК та СП

Код	Загроза	STRIDE	Порушник	Активи	Вразливість
З-01	Цільовий фішинг і викрадення облікових даних операторів Реєстру	S, E	ПР-1, ПР-4	А-01, А-09	відсутність MFA, недостатня обізнаність
З-02	Несанкціонована зміна облікових записів військовозобов’язаних (корупційне втручання)	T, R	ПР-3	А-01, А-02	надмірні права, слабкий аудит змін
З-03	Витік персональних і медичних даних	I	ПР-1, ПР-3	А-01, А-02, А-04	відсутність DLP, незашифровані копії
З-04	DDoS-атака на сервіс електронної черги	D	ПР-2	А-08	відсутність фільтрації трафіку, єдиний канал
З-05	Атака через ланцюг постачання (шкідливе оновлення ПЗ)	T, E	ПР-5, ПР-1	А-06, А-07	відсутність перевірки цілісності оновлень
З-06	Програма-вимагач або вайпер у локальній мережі	D, T	ПР-1	А-06, А-10, А-12	пласка мережа, онлайн-резервні копії
З-07	Фізичне проникнення, підключення пристрою, крадіжка носія	I, T	ПР-6, ПР-3	А-03, А-05, А-06	слабкий контроль доступу до приміщень, відкриті USB-порти
З-08	Компрометація засобів КЗІ та ключових документів	S, I	ПР-1, ПР-3	А-05, А-07	порушення правил обліку ключів
З-09	Заперечення виконаних дій операторами (відсутність доказовості)	R	ПР-3	А-01, А-10	неповне журналювання, незахищені журнали
З-10	Відмова обладнання або живлення під час обстрілів	D	—	А-06, А-07, А-12	відсутність резервного живлення та каналу

5.4. Структурна модель системи інформаційної безпеки

Структурну модель системи інформаційної безпеки ТЦК та СП подано на рис. 1.3; вона повторює структуру рисунка 1.1 методичних рекомендацій [1] з наповненням за варіантом. Порушники (табл. 1.6) здійснюють атаки, що реалізують загрози конфіденційності, цілісності та доступності. Загрози використовують вразливості й разом з ними створюють ризики, які загрожують ресурсам (табл. 1.5). Власник ресурсів — начальник ТЦК та СП — встановлює контрзаходи, що зменшують вразливості. Загрози, вразливості,

ризики та контрзаходи розташовані в межах інформаційного простору установи, тоді як порушник і власник перебувають за його межами.

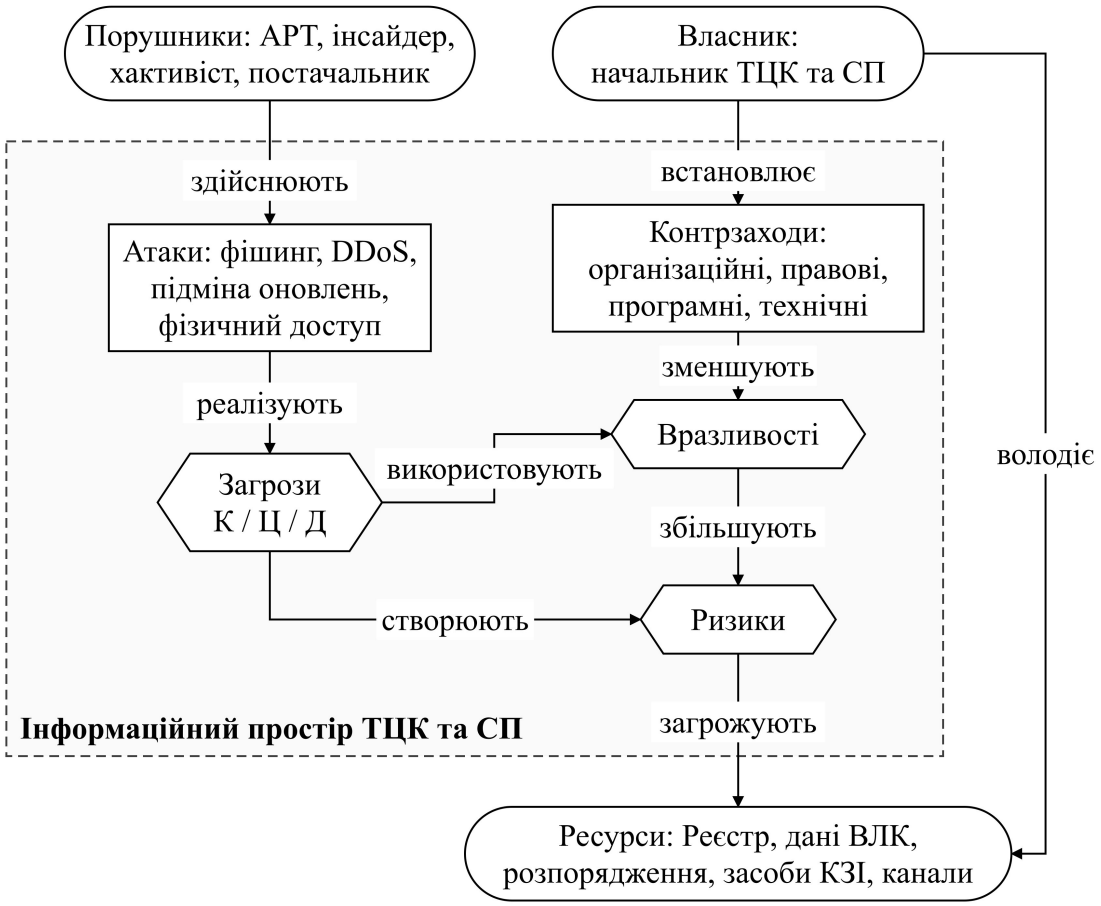


Рис. 1.3 — Модель системи інформаційної безпеки ТЦК та СП

5.5. Архітектура периметра захисту

Технічну складову моделі — архітектуру периметра захисту з п’ятьма зонами довіри — подано на рис. 1.4. Вона реалізує принцип багаторівневого захисту та мережевої сегментації, що обмежує латеральне переміщення порушника [18].

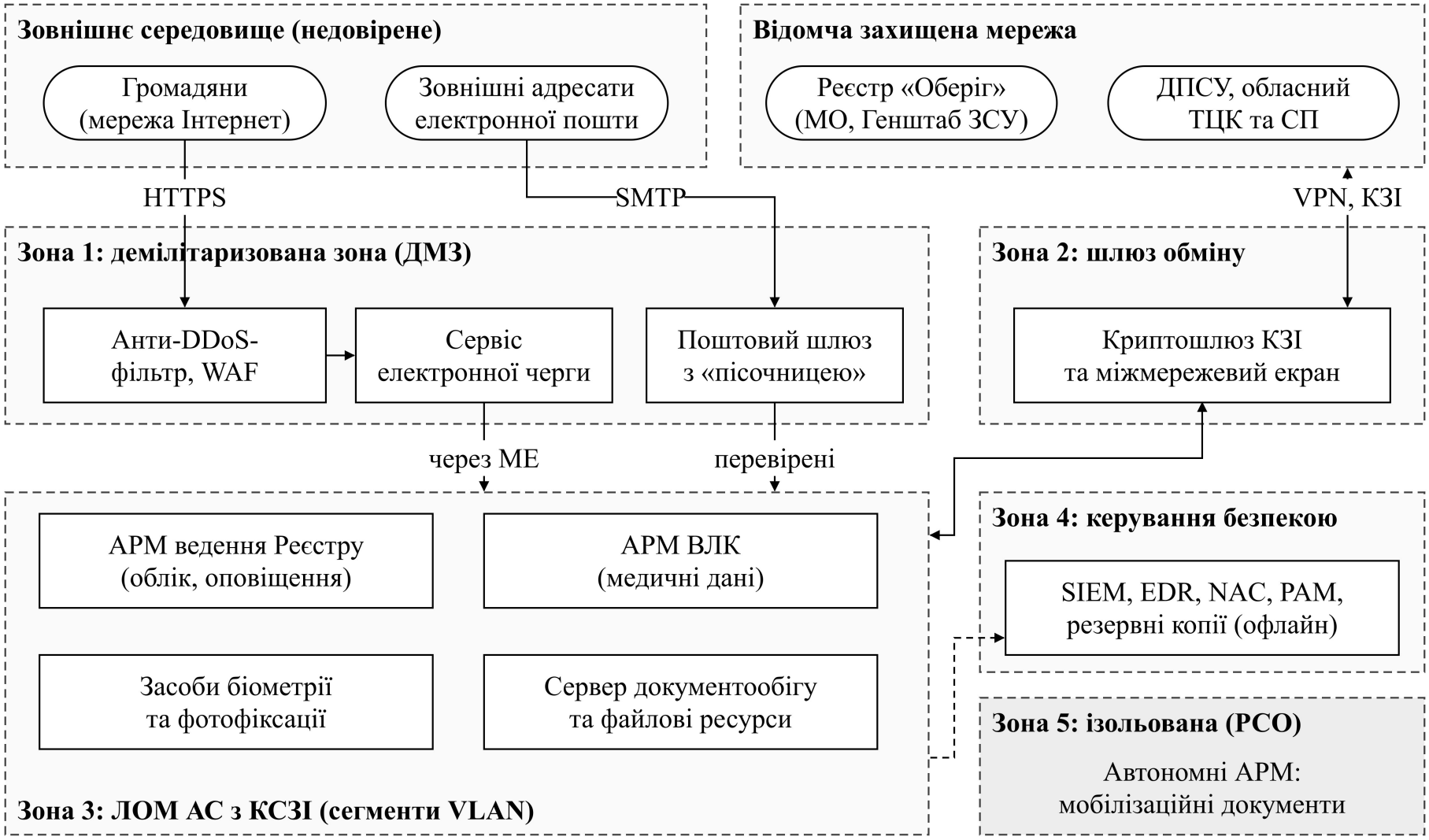


Рис. 1.4 — Архітектура периметра захисту та зони довіри ТЦК та СП

На рис. 1.4 суцільні стрілки позначають дозволені потоки даних, пунктирна — передавання журналів подій до зони керування безпекою; зона 5 не має мережевих з’єднань. Призначення зон:

– Зовнішнє середовище: громадяни та зовнішні адресати пошти — недовірені джерела трафіку.

– Зона 1 (ДМЗ): анти-DDoS-фільтр і WAF перед сервісом електронної черги, поштовий шлюз з «пісочницею» для перевірки вкладень; з ДМЗ до ЛОМ дозволено лише визначені потоки через міжмережевий екран.

– Зона 2: криптошлюз з засобами КЗІ, що мають позитивний експертний висновок, забезпечує захищений обмін з відомчою мережею (Реєстр «Оберіг», ДПСУ, обласний ТЦК та СП).

– Зона 3: ЛОМ автоматизованої системи з КСЗІ, поділена на VLAN за функціями (Реєстр, ВЛК, біометрія, документообіг); для неї доцільний клас АС 3 (розподілений комплекс) за НД ТЗІ 2.5-005-99 [19].

– Зона 4: SIEM, EDR, контроль мережевого доступу (NAC), керування привілейованим доступом (PAM) і офлайн-резервні копії; сюди надходять журнали з усіх зон.

– Зона 5: ізольовані автономні АРМ РСО (клас АС 1) для мобілізаційних документів з грифом секретності, без підключення до будь-яких мереж.

6. КІБЕРБЕЗПЕКА ТЦК ТА СП НА БАЗІ ISO/IEC 27001

6.1. Процес управління ризиками

З погляду процесного підходу систему інформаційної безпеки подають як процес управління ризиками з шести складових: опис бізнес-процесів, збір ризиків, оцінка ризиків, планування заходів, реалізація заходів і оцінка ефективності [1]. Наповнення кожної складової для ТЦК та СП подано на рис. 1.5; процес відповідає вимогам 6.1.2, 6.1.3, 8.2 і 8.3 ISO/IEC 27001:2022 [7] та методології NIST SP 800-30 [20].

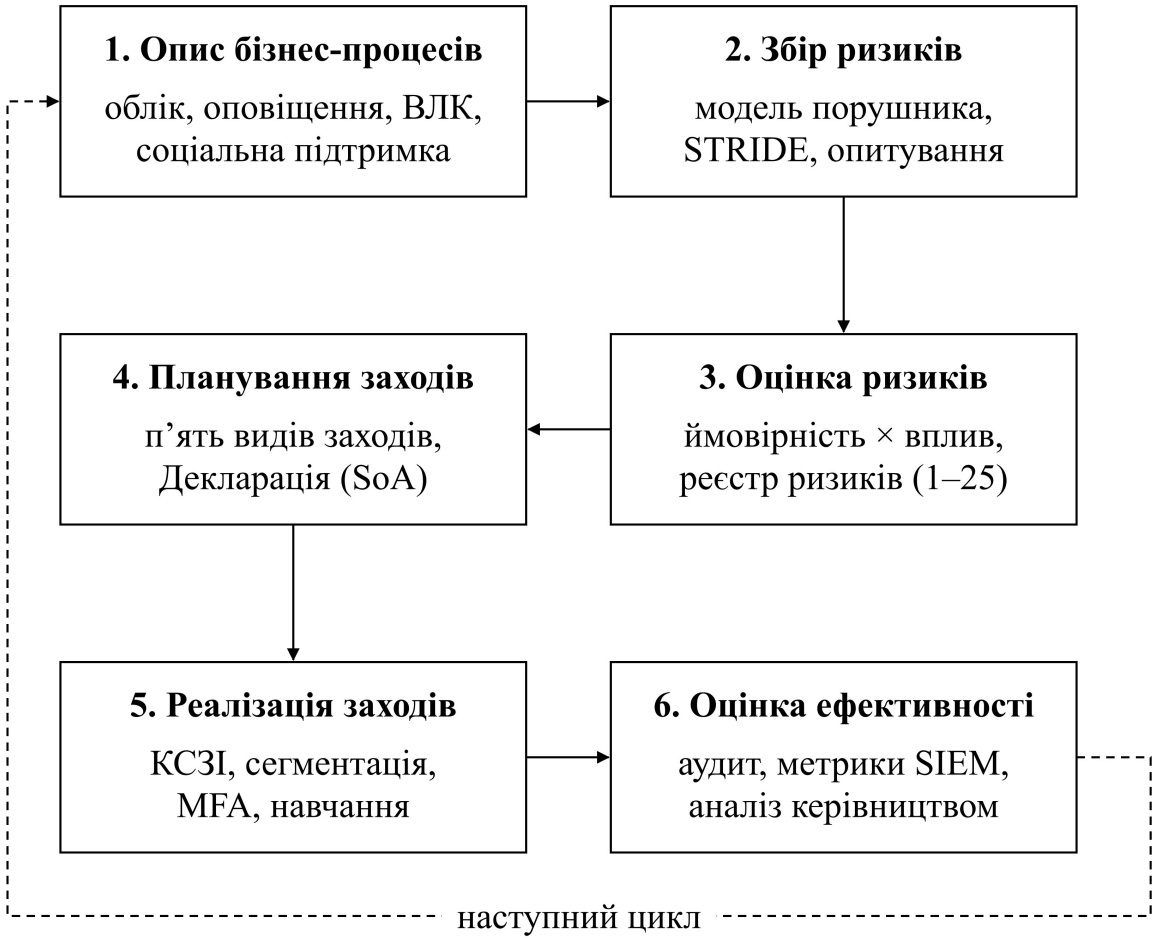


Рис. 1.5 — Процес управління ризиками кібербезпеки ТЦК та СП

6.2. Оцінка ризиків

Ризик оцінено як добуток ймовірності реалізації загрози (1–5) на величину впливу (1–5). Рівні: 1–7 — низький, 8–14 — середній, 15–25 — високий. Результати наведено в табл. 1.8.

Таблиця 1.8 — Оцінка ризиків кібербезпеки ТЦК та СП

Код	Загроза	Ймовірність	Вплив	Ризик	Рівень
З-01	Цільовий фішинг і викрадення облікових даних операторів Реєстру	4	5	20	високий
З-02	Несанкціонована зміна облікових записів військовозобов’язаних (корупційне втручання)	3	5	15	високий
З-03	Витік персональних і медичних даних	3	5	15	високий
З-04	DDoS-атака на сервіс електронної черги	4	3	12	середній
З-05	Атака через ланцюг постачання (шкідливе оновлення ПЗ)	2	5	10	середній
З-06	Програма-вимагач або вайпер у локальній мережі	3	5	15	високий
З-07	Фізичне проникнення, підключення пристрою, крадіжка носія	2	5	10	середній
З-08	Компрометація засобів КЗІ та ключових документів	2	5	10	середній
З-09	Заперечення виконаних дій операторами (відсутність доказовості)	3	3	9	середній
З-10	Відмова обладнання або живлення під час обстрілів	3	4	12	середній

Високий рівень мають 4 ризики, середній — 6, низький — 0. Високі ризики: З-01 — цільовий фішинг і викрадення облікових даних операторів Реєстру (20); З-02 — несанкціонована зміна облікових записів військовозобов’язаних (корупційне втручання) (15); З-03 — витік персональних і медичних даних (15); З-06 — програма-вимагач або вайпер у локальній мережі (15). Високі ризики підлягають обов’язковій обробці (зменшенню), середні — зменшенню в межах ресурсів; залишкові ризики приймає власник — начальник ТЦК та СП.

6.3. Обробка ризиків і Декларація про застосовність

Для кожної загрози обрано заходи додатка A ISO/IEC 27001:2022 [7], визначено відповідні категорії NIST CSF 2.0 [21] і вид заходу за класифікацією методичних рекомендацій (організаційні, правові, організаційно-технічні,

програмні, інженерно-технічні) [1]. Отримане відображення (табл. 1.9) є основою ДЗ.

Таблиця 1.9 — Відображення загроз на заходи ISO/IEC 27001:2022 і категорії NIST CSF 2.0

Загроза	Заходи додатка A ISO/IEC 27001:2022	NIST CSF 2.0	Вид заходу
З-01	5.17, 8.5 — автентифікаційна інформація, безпечна автентифікація (MFA); 6.3 — навчання; 8.23 — вебфільтрація	PR.AA, PR.AT	програмний, організаційний
З-02	5.3 — розподіл обов'язків; 5.18, 8.2 — права доступу, привілейований доступ; 8.15 — журналювання	PR.AA, DE.CM	організаційно-технічний
З-03	5.12 — класифікація; 5.34 — захист персональних даних; 8.11, 8.12 — маскування, запобігання витоку; 8.24 — криптографія	PR.DS, GV.PO	правовий, програмний
З-04	8.6 — керування потужністю; 8.14 — резервування; 8.20, 8.21 — безпека мереж і мережевих сервісів	PR.IR, RC.RP	інженерно-технічний
З-05	5.19–5.22 — безпека відносин з постачальниками та ланцюга постачання ІКТ; 8.19 — встановлення ПЗ; 8.32 — керування змінами	GV.SC, ID.RA	організаційний, програмний
З-06	8.7 — захист від шкідливого ПЗ; 8.13 — резервне копіювання; 8.22 — сегрегація мереж; 5.30 — готовність ІКТ до неперервності	PR.PS, RC.RP	програмний, інженерно-технічний
З-07	7.1–7.4 — фізичний периметр, вхід, моніторинг; 7.10 — носії; 7.14 — безпечна утилізація	PR.AA, DE.CM	інженерно-технічний
З-08	8.24 — використання криптографії; 5.9 — інвентаризація активів; 7.6 — робота в захищених зонах	PR.DS, ID.AM	організаційно-технічний
З-09	8.15 — журналювання; 8.16 — моніторинг; 8.17 — синхронізація годинників; 5.28 — збирання доказів	DE.AE, RS.AN	програмний
З-10	7.11 — допоміжні комунікації (живлення); 5.29, 5.30 — безпека під час порушень, готовність ІКТ; 8.14 — резервування	RC.RP, PR.IR	інженерно-технічний, організаційний

Розподіл посилань на функції NIST CSF 2.0: Govern — 2; Identify — 2; Protect — 9; Detect — 3; Respond — 1; Recover — 3. Переважання функції Protect закономірне для етапу створення СУІБ; функції Respond і Govern додатково забезпечуються процедурою реагування на інциденти та політикою безпеки (підрозділ 4.3).

6.4. Узгодження з національною нормативною базою

Сертифікація за ISO/IEC 27001 для державного органу є добровільною, тоді як вимоги національного законодавства обов'язкові. Тому СУІБ ТЦК та СП поєднує два контури: управлінський (ISO/IEC 27001, NIST CSF) і

нормативно-технічний (КСЗІ за НД ТЗІ з підтвердженням відповідності, режим секретності, захист персональних даних) [13; 15]. Ризики та заходи, обрані за ISO/IEC 27001, стають вихідними даними для технічного завдання на КСЗІ, а результати державної експертизи КСЗІ — свідченням результативності для внутрішнього аудиту за розділом 9.

Реагування на інциденти організовано за циклом «планування та підготовка — виявлення та реагування — аналіз і розслідування — оцінювання та вдосконалення» з обов’язковою взаємодією із зовнішніми центрами реагування (CERT-UA) [10].

7. СТАНДАРТИ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ ДЛЯ ТЦК ТА СП

За завданням 6 досліджено стандарти серії ISO/IEC 27000 з переліку методичних рекомендацій [1] і доповнено їх нормативними документами України та рамками NIST, необхідними для захисту ТЦК та СП. Результат (форма таблиці 1.1 методичних рекомендацій) наведено в табл. 1.10; для стандартів серії ISO/IEC 27000 зазначено поточні редакції без року, якщо їх кілька.

Таблиця 1.10 — Стандарти та їх опис

Стандарт	Короткий зміст	Застосування в ТЦК та СП
ISO/IEC 27001:2022 (в Україні — ДСТУ ISO/IEC 27001:2023, IDT)	Вимоги до створення, впровадження, підтримання та постійного поліпшення СУІБ; 93 заходи додатка А	Основа СУІБ ТЦК та СП: область застосування П1–П7, реєстр ризиків, Декларація про застосовність
ISO/IEC 27002:2022	Настанови щодо впровадження заходів безпеки з атрибутами (тип заходу, властивості, концепції кібербезпеки)	Деталізація заходів MFA, DLP, журналювання, сегментації для АРМ Реєстру та ВЛК
ISO/IEC 27003	Настанова з реалізації СУІБ	Покроковий план впровадження СУІБ у районному ТЦК та СП
ISO/IEC 27004	Моніторинг, вимірювання, аналіз і оцінювання СУІБ	Метрики: частка операторів з MFA, час реагування на інцидент, результати фішинг-тренувань
ISO/IEC 27005	Керування ризиками інформаційної безпеки	Методика оцінювання ризиків З-01…З-10 (ймовірність × вплив)
ISO/IEC 27006	Вимоги до органів аудиту та сертифікації СУІБ	Вимоги до зовнішніх аудиторів у разі незалежного оцінювання
ISO/IEC 27007, ISO/IEC TS 27008	Настанови з аудиту СУІБ і аудиту заходів	Програма внутрішніх аудитів СУІБ і перевірок технічних заходів
ISO/IEC 27010	Менеджмент ІБ для міжгалузевих і міжорганізаційних комунікацій	Правила обміну з МО, Генштабом ЗСУ, ДПСУ, обласним ТЦК та СП
ISO/IEC 27011	Настанова для телекомунікаційних організацій	Обмежено: вимоги до операторів каналів зв’язку, якими користується ТЦК та СП
ISO/IEC 27013	Інтегрована реалізація ISO/IEC 20000-1 і ISO/IEC 27001	Узгодження ІТ-сервісів групи ІКТ з вимогами СУІБ
ISO/IEC 27014	Врядування інформаційною безпекою	Відповідальність керівництва, звітування начальнику ТЦК та СП
ISO/IEC TR 27015:2012	Настанови для фінансових послуг; скасований у 2017 р. без заміни	Не застосовується: документ скасовано, фінансових послуг ТЦК та СП не надає
ISO/IEC 27031	Готовність ІКТ до неперервності бізнесу	Резервні канали, живлення, план відновлення Реєстрового АРМ

Продовження таблиці 1.10

Стандарт	Короткий зміст	Застосування в ТЦК та СП
ISO/IEC 27033 (усі частини)	Безпека мереж	Сегментація зон 1–5, захист периметра
ISO/IEC 27034 (усі частини)	Безпека застосунків	Вимоги до сервісу електронної черги та його постачальника
ISO/IEC 27035	Менеджмент інцидентів ІБ	Процедура реагування, взаємодія з CERT-UA
ISO/IEC 27037	Ідентифікація, збирання та збереження цифрових доказів	Збереження доказів у разі корупційного втручання або атаки
Закон України «Про основні засади забезпечення кібербезпеки України» № 2163-VIII	Засади кібербезпеки, суб'єкти національної системи кібербезпеки, захист критичної інфраструктури	Обов'язок кіберзахисту державних інформаційних ресурсів, повідомлення CERT-UA про інциденти
Закон України «Про захист персональних даних» № 2297-VI	Правила обробки персональних даних, особливі категорії (ст. 7), обов'язки володільця	Обробка даних громадян і медичних даних ВЛК, призначення відповідальної особи
Закон України «Про захист інформації в інформаційно-комунікаційних системах» № 80/94-ВР	Захист державних інформаційних ресурсів і інформації з обмеженим доступом в системах	Обов'язковість КСЗІ з підтвердженою відповідністю для АРМ Реєстру та документообігу
Закон України «Про Єдиний державний реєстр призовників, військовозобов'язаних та резервістів» № 1951-VIII	Склад Реєстру, держатель і адміністратор (МО), розпорядник (Генштаб ЗСУ), порядок ведення і обміну	Повноваження ТЦК та СП як органу ведення, вимоги до захисту даних Реєстру
Закон України «Про державну таємницю» № 3855-XII	Режим секретності, допуск і доступ до секретної інформації	Робота РСО з мобілізаційними документами в ізольованій зоні
НД ТЗІ 3.7-003-05	Порядок створення КСЗІ в інформаційно-телекомунікаційній системі	Етапи створення КСЗІ АС ТЦК та СП, державна експертиза
НД ТЗІ 2.5-004-99, НД ТЗІ 2.5-005-99	Критерії оцінки захищеності, класифікація АС і функціональні профілі	Вибір функціонального профілю для ЛОМ з АРМ Реєстру (АС класу 3) і автономних АРМ (клас 1)
NIST Cybersecurity Framework 2.0	Шість функцій: Govern, Identify, Protect, Detect, Respond, Recover	Перевірка повноти заходів і звітування керівництву за функціями
NIST SP 800-30 Rev. 1, NIST SP 800-34 Rev. 1	Оцінювання ризиків; планування неперервності	Сценарії відновлення роботи під час відключень і атак

Отже, базовим для ТЦК та СП є поєднання ISO/IEC 27001/27002/27005 (управління ризиками та заходи), ISO/IEC 27035 і 27031 (інциденти та неперервність), законів України щодо кібербезпеки, персональних даних, захисту інформації, Реєстру й державної таємниці та НД ТЗІ щодо КСЗІ. Наведений у переліку методичних рекомендацій ISO/IEC TR 27015:2012 не

застосовується: його скасовано без заміни, а фінансових послуг ТЦК та СП не надає.

8. ВІДПОВІДІ НА ПИТАННЯ ДЛЯ САМОПЕРЕВІРКИ

Питання 1. Яким чином визначаються терміни інформаційної безпеки? Назвіть приклади.

Відповідь. Терміни визначаються законодавством, національними та міжнародними стандартами і вводяться в СУІБ політикою безпеки, щоб усі учасники однаково їх розуміли. Приклади: конфіденційність, цілісність, доступність, загроза, вразливість, ризик, інцидент, актив, власник ризику (підрозділ 2.2).

Питання 2. Розкрийте поняття «заходи інформаційної безпеки».

Відповідь. Заходи — це організаційні, правові, програмні та технічні дії й засоби, що зменшують ймовірність реалізації загроз або їх вплив. У ISO/IEC 27001:2022 їх 93 у чотирьох темах; для ТЦК та СП відібрані заходи наведено в табл. 1.9.

Питання 3. Яким чином може здійснюватися забезпечення фізичної безпеки та безпеки персоналу?

Відповідь. Фізична безпека: периметр і контроль входу, захищені зони, відеомоніторинг, захист носіїв і живлення, безпечна утилізація (заходи 7.1–7.14). Безпека персоналу: перевірка кандидатів і оформлення допуску, зобов’язання про нерозголошення, навчання, дисциплінарна відповідальність, відкликання прав після звільнення (заходи 6.1–6.8).

Питання 4. Яким чином відбувається аналіз ризиків?

Відповідь. Описують об’єкт і наявні заходи, ідентифікують ресурси, аналізують загрози й вразливості, оцінюють ймовірність і вплив, визначають рівень ризику та порівнюють його з критеріями прийнятності (табл. 1.8).

Питання 5. Розкрийте поняття «об’єкти захисту», що до них відноситься, наведіть приклади.

Відповідь. Об’єкти захисту — інформація та матеріальні ресурси, які необхідно захищати: інформаційні, програмні, апаратні, мережеві ресурси і

бізнес-процеси. Приклади для ТЦК та СП — відомості Реєстру, висновки ВЛК, засоби КЗІ, процес оповіщення (табл. 1.5).

Питання 6. Що таке «загрози»? Їх види та джерела. Наведіть приклади.

Відповідь. Загроза — потенційна можливість події, що порушує конфіденційність, цілісність або доступність. За природою загрози бувають випадковими й навмисними, за джерелом — зовнішніми та внутрішніми. Приклади: цільовий фішинг APT-угруповання, DDoS-атака хактивістів, корупційна зміна записів інсайдером, відмова живлення (табл. 1.7).

Питання 7. Види заходів інформаційної безпеки. Докладно розкрийте кожен з них.

Відповідь. Організаційні — політики, ролі, регламенти, навчання; правові — закони, договори, зобов’язання про нерозголошення, відповідальність; організаційно-технічні — допуск, облік ключів, керування змінами; програмні — автентифікація, антивірусний захист, журналювання, шифрування; інженерно-технічні — фізичний захист, резервне живлення, мережеве обладнання та засоби КЗІ.

Питання 8. Яким чином і з якою метою відбувається оцінка ефективності системи управління кібербезпекою? Назвіть ключові чинники успішності.

Відповідь. Оцінка — системне отримання об’єктивних даних про стан системи та їх порівняння з критеріями шляхом моніторингу, метрик, внутрішнього аудиту й аналізу керівництвом. Мета — визначити рівень ефективності, вузькі місця, відповідність стандартам і виробити рекомендації. Ключовий чинник успішності — побудова СУІБ на базі ISO/IEC 27001 за підтримки керівництва та з урахуванням ризиків.

Питання 9. Які основні вимоги міжнародних стандартів ISO/IEC 27001? З яких елементів складається стандарт?

Відповідь. Стандарт вимагає визначити контекст і область СУІБ, забезпечити лідерство й політику, оцінювати та обробляти ризики, підтримувати ресурси та документацію, оцінювати результативність і

постійно поліпшувати систему. Складається з розділів 0–10 (обов’язкові 4–10) та додатка А з 93 заходами (табл. 1.2 і 1.3).

Питання 10. Які основні стандарти серії ISO 27К ви знаєте?

Відповідь. ISO/IEC 27000 (огляд і словник), 27001 (вимоги до СУІБ), 27002 (заходи), 27003 (впровадження), 27004 (вимірювання), 27005 (ризики), 27006 і 27007 (аудит і сертифікація), 27014 (врядування), 27031 (неперервність ІКТ), 27033 (мережі), 27034 (застосунки), 27035 (інциденти), 27037 (цифрові докази) — див. табл. 1.10.

ВИСНОВКИ

У лабораторній роботі досліджено структуру системи управління кібернетичною безпекою військкомату — районного ТЦК та СП — на основі стандарту ISO/IEC 27001:2022 і національної нормативної бази.

1) Розкрито поняття інформаційної та кібербезпеки, цілі (модель CIA та додаткові принципи) і завдання СУІБ; кожну ціль конкретизовано для ТЦК та СП (табл. 1.1).

2) Проаналізовано ISO/IEC 27001:2022: обов'язкові розділи 4–10, цикл PDCA, 93 заходи додатка А в чотирьох темах і зміни редакції 2022 р.

3) Визначено контекст, зацікавлені сторони й область застосування СУІБ ТЦК та СП: 7 процесів, 12 активів, з яких 5 мають максимальну критичність за К, Ц і Д.

4) Побудовано модель системи інформаційної безпеки за структурою методичних рекомендацій, модель порушника (6 типів) і архітектуру периметра з п'ятьма зонами довіри.

5) Оцінено 10 ризиків: високих — 4, середніх — 6; для кожного обрано заходи додатка А та категорії NIST CSF 2.0, що утворює основу Декларації про застосовність.

6) Заповнено таблицю стандартів (26 позицій), що поєднує серію ISO/IEC 27000, закони України, НД ТЗІ та рамки NIST.

Аналіз результатів показує, що найбільші ризики ТЦК та СП пов'язані не з периметром, а з людським чинником: фішингом проти операторів Реєстру та корупційним втручанням у записи. Тому пріоритетними є багатофакторна автентифікація, розподіл обов'язків, захищене журналювання та навчання персоналу, а сертифікована КСЗІ і сегментація мережі мають доповнювати ці заходи, а не замінювати їх.

СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ

1. Борисенко І. І., Гладка М. В. Кібернетична безпека підприємства : рекомендації до виконання лабораторних робіт для здобувачів освітнього ступеня «бакалавр» спеціальності 126 «Інформаційні системи та технології». Київ : КНУ імені Тараса Шевченка, 2025. 33 с.

2. Про затвердження Положення про територіальні центри комплектування та соціальної підтримки : постанова Кабінету Міністрів України від 23.02.2022 № 154. URL: https://zakon.rada.gov.ua/laws/show/154-2022-п (дата звернення: 04.10.2026).

3. ДСТУ 3008:2015. Інформація та документація. Звіти у сфері науки і техніки. Структура та правила оформлювання. Київ : ДП «УкрНДНЦ», 2016. 26 с.

4. Управління інформаційною безпекою : конспект лекцій / уклад.: С. О. Носок, О. М. Фаль, В. М. Ткач. Київ : КПІ ім. Ігоря Сікорського, 2021. 258 с.

5. Кібернетична безпека підприємства: поняття, принципи та сучасні виклики : лекція 1 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

6. Про основні засади забезпечення кібербезпеки України : Закон України від 05.10.2017 № 2163-VIII. URL: https://zakon.rada.gov.ua/laws/show/2163-19 (дата звернення: 04.10.2026).

7. ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva : ISO, 2022.

8. ДСТУ ISO/IEC 27001:2023. Інформаційна безпека, кібербезпека та захист конфіденційності. Системи керування інформаційною безпекою. Вимоги (ISO/IEC 27001:2022, IDT). Чинний від 22.08.2023. Київ : ДП «УкрНДНЦ», 2023.

9. ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection — Information security controls. Geneva : ISO, 2022.

10. Організаційний та процедурний рівень кібернетичної безпеки підприємства : лекція 5 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

11. Про Єдиний державний реєстр призовників, військовозобов'язаних та резервістів : Закон України від 16.03.2017 № 1951-VIII. URL: https://zakon.rada.gov.ua/laws/show/1951-19 (дата звернення: 04.10.2026).

12. Про захист персональних даних : Закон України від 01.06.2010 № 2297-VI. URL: https://zakon.rada.gov.ua/laws/show/2297-17 (дата звернення: 04.10.2026).

13. Про захист інформації в інформаційно-комунікаційних системах : Закон України від 05.07.1994 № 80/94-ВР. URL: https://zakon.rada.gov.ua/laws/show/80/94-вр (дата звернення: 04.10.2026).

14. Про державну таємницю : Закон України від 21.01.1994 № 3855-XII. URL: https://zakon.rada.gov.ua/laws/show/3855-12 (дата звернення: 04.10.2026).

15. НД ТЗІ 3.7-003-05. Порядок проведення робіт із створення комплексної системи захисту інформації в інформаційно-телекомунікаційній системі. Київ : ДСТСЗІ СБ України, 2005.

16. Порушник у системі кібернетичної безпеки підприємства : лекція 4 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

17. Кіберзагрози, вразливості та моделювання атак на підприємство : лекція 3 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

18. Архітектура кібербезпеки підприємства та захист IoT-інфраструктури : лекція 2 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

19. НД ТЗІ 2.5-005-99. Класифікація автоматизованих систем і стандартні функціональні профілі захищеності оброблюваної інформації від несанкціонованого доступу. Київ : ДСТСЗІ СБ України, 1999.

20. Guide for Conducting Risk Assessments : NIST Special Publication 800-30 Revision 1. Gaithersburg : National Institute of Standards and Technology, 2012. 95 p.

21. The NIST Cybersecurity Framework (CSF) 2.0 : NIST CSWP 29. Gaithersburg : National Institute of Standards and Technology, 2024. 32 p.